

Risk Scoring Report — Dependency Scan

Project: vulnerable-invoice-service · Stage 2 Risk Scoring · Generated 2026-06-28 · SHA 61ed8c3

Summary

Metric	Count
Total dependencies scanned	24
Vulnerable dependencies	9
Outdated dependencies	8
License violations / warnings	1
Supply-chain alerts	1

Risk Band Distribution (scored dependencies)

Band	Count
CRITICAL	0
HIGH	6
MEDIUM	3
LOW	0

Supply-Chain Alerts

CRITICAL — Typosquatted dependency detected.

`com.fastxml.jackson.core:jackson-databind:2.9.8` — groupId `com.fastxml` impersonates the legitimate `com.fasterxml.jackson.core`. This artifact does not exist on Maven Central and is blocked by Maven's artifact resolution. Remove immediately and confirm no rogue jar was cached in CI.

HIGH — Untrusted plain-HTTP repository.

`http://insecure-mirror.example.net/maven2` declared in `pom.xml`. Maven's default HTTP mirror blocker prevents resolution, but this repository must be removed to eliminate the supply-chain attack vector entirely.

Ranked Remediation Backlog

#	Coordinate	Risk Score	Band	CVE Count	Top CVE	CVSS	Fix Version
1	<code>org.apache.logging.log4j:log4j-core:2.14.1</code>	7.8	HIGH	8	CVE-2021-44228	10.0	2.17.1

2	com.fasterxml.jackson.core:jackson-databind:2.9.8	7.8	HIGH	54	CVE-2019-14379	9.8	2.17.1
3	mysql:mysql-connector-java:8.0.30	7.6	HIGH	1	CVE-2023-22102	8.3	8.0.33
4	org.apache.logging.log4j:log4j-api:2.14.1	6.8	HIGH	2	CVE-2026-34479	7.5	2.24.3
5	com.google.protobuf:protobuf-java:3.19.4	6.7	HIGH	4	CVE-2024-7254	7.5	3.25.5
6	com.google.guava:guava:24.1.1-jre	6.3	HIGH	2	CVE-2023-2976	7.1	32.0.0-jre
7	com.fasterxml.jackson.core:jackson-annotations:2.9.0	5.5	MEDIUM	1	CVE-2018-1000873	6.5	2.17.1
8	commons-io:commons-io:2.4	5.2	MEDIUM	2	CVE-2021-29425	4.8	2.14.0
9	org.apache.commons:commons-lang3:3.4	5.2	MEDIUM	1	CVE-2025-48924	5.3	3.14.0

Detailed Findings

org.apache.logging.log4j:log4j-core:2.14.1

Risk Score: 7.8 **HIGH**
Top CVE: CVE-2021-44228 (CVSS 10.0)
CVE Count: 8
Fix Version: 2.17.1

Component	Score
CVE Severity	10.0
Exposure	8.0
Business Criticality	2.0

Rationale: Used in DiscountCalculator (internal service layer) for logging; top CVE CVE-2021-44228 CVSS 10.0 (CRITICAL); 8 total CVEs.

com.fasterxml.jackson.core:jackson-databind:2.9.8

Risk Score: 7.8 **HIGH**
Top CVE: CVE-2019-14379 (CVSS 9.8)
CVE Count: 54
Fix Version: 2.17.1

Component	Score
CVE Severity	10.0
Exposure	8.0
Business Criticality	2.0

Rationale: JSON deserialization library used in invoice service — internal API layer; top CVE CVE-2019-14379 CVSS 9.8 (CRITICAL); 54 total CVEs.

mysql:mysql-connector-java:8.0.30

Risk Score: 7.6 HIGH
Top CVE: CVE-2023-22102 (CVSS 8.3)
CVE Count: 1
Fix Version: 8.0.33

Component	Score
CVE Severity	8.3
Exposure	8.0
Business Criticality	5.0

Rationale: Database connector for invoice service — handles financial/PII data; top CVE CVE-2023-22102 CVSS 8.3 (HIGH); 1 total CVEs.

`org.apache.logging.log4j:log4j-api:2.14.1`

Risk Score: 6.8 HIGH
Top CVE: CVE-2026-34479 (CVSS 7.5)
CVE Count: 2
Fix Version: 2.24.3

Component	Score
CVE Severity	8.0
Exposure	8.0
Business Criticality	2.0

Rationale: Logging API used directly in DiscountCalculator — internal service; top CVE CVE-2026-34479 CVSS 7.5 (HIGH); 2 total CVEs.

`com.google.protobuf:protobuf-java:3.19.4`

Risk Score: 6.7 HIGH
Top CVE: CVE-2024-7254 (CVSS 7.5)
CVE Count: 4
Fix Version: 3.25.5

Component	Score
CVE Severity	9.0
Exposure	6.0
Business Criticality	2.0

Rationale: Transitive via mysql-connector — serialization protocol library; top CVE CVE-2024-7254 CVSS 7.5 (HIGH); 4 total CVEs.

`com.google.guava:guava:24.1.1-jre`

Risk Score: 6.3 HIGH
Top CVE: CVE-2023-2976 (CVSS 7.1)
CVE Count: 2
Fix Version: 32.0.0-jre

Component	Score
CVE Severity	7.6
Exposure	7.0

Business Criticality	2.0
----------------------	-----

Rationale: General utility library — no direct usage in src found; default internal service; top CVE CVE-2023-2976 CVSS 7.1 (HIGH); 2 total CVEs.

`com.fasterxml.jackson.core:jackson-annotations:2.9.0`

Risk Score: 5.5 **MEDIUM**

Top CVE: CVE-2018-1000873 (CVSS 6.5)

CVE Count: 1

Fix Version: 2.17.1

Component	Score
CVE Severity	6.5
Exposure	6.0
Business Criticality	2.0

Rationale: Transitive jackson annotation library — internal service; top CVE CVE-2018-1000873 CVSS 6.5 (MEDIUM); 1 total CVEs.

`commons-io:commons-io:2.4`

Risk Score: 5.2 **MEDIUM**

Top CVE: CVE-2021-29425 (CVSS 4.8)

CVE Count: 2

Fix Version: 2.14.0

Component	Score
CVE Severity	5.3
Exposure	7.0
Business Criticality	2.0

Rationale: File I/O utility — general internal service usage; top CVE CVE-2021-29425 CVSS 4.8 (MEDIUM); 2 total CVEs.

`org.apache.commons:commons-lang3:3.4`

Risk Score: 5.2 **MEDIUM**

Top CVE: CVE-2025-48924 (CVSS 5.3)

CVE Count: 1

Fix Version: 3.14.0

Component	Score
CVE Severity	5.3
Exposure	7.0
Business Criticality	2.0

Rationale: String utility library — general internal service usage; top CVE CVE-2025-48924 CVSS 5.3 (MEDIUM); 1 total CVEs.

Scoring Methodology

`risk_score = 0.5 × cve_severity + 0.3 × exposure + 0.2 × business_criticality`

- **CVE Severity** (0–10): maximum CVSS base score + density bonus (0.5 per additional CVE, capped at 10).
- **Exposure** (0–10): direct/transitive (+4/+2), compile/test scope (+3/+1), network/serialization library (+1).

- **Business Criticality** (0–10): auth/payment/PII (+5), public API (+3), internal service (+2), build/test (+1).
- **CRITICAL floor**: any dependency with a CRITICAL CVE is floored at band HIGH regardless of weighted score.

`depscan-risk-report.json` is ready for the **Auto-Remediation Skill** (Stage 3) and the **PR Validation Agent** (Stage 4).